SECCIÓN 4.5

Persistencia y mantenimiento de acceso

Temas de esta sección:

- Qué es la persistencia y por qué la busca una amenaza
- Diferencia entre ejecución inicial y persistencia
- Tareas programadas y claves Run del registro
- Servicios de Windows y carpeta de inicio
- Nuevos usuarios, cambios de grupos y persistencia en navegador
- Persistencia en correo y cloud (reglas, MFA, OAuth)
- Nombres engañosos y cómo documentar persistencia

No es lo mismo. La ejecución inicial responde '¿cómo empezó?' La persistencia responde '¿cómo intenta mantenerse?'

EJECUCIÓN INICIAL — cómo empezó	PERSISTENCIA — cómo intenta mantenerse
Usuario abre Factura_2026.exe desde Downloads	Factura_2026.exe crea una tarea programada para ejecutar update.exe cada 10 minutos

Una amenaza con persistencia busca:

- Sobrevivir a reinicios del equipo
- Mantener acceso aunque se cierre el proceso
- Ejecutarse periódicamente para reportar
- Recuperar comunicación con C2
- Continuar recolectando información

4.5 | Mecanismos de persistencia: comparativo legítimo vs sospechoso

Los mismos mecanismos son usados por software legítimo y por malware. El contexto diferencia:

Mecanismo	Contexto legítimo	Contexto sospechoso
Tarea programada	SecurityAgentHealthCheck → C:\Program Files\Agent\hc.exe	OneDriveUpdate → C:\Users\Public\update.exe (creada por WINWORD→PS)
Registro Run	Aplicación corporativa → C:\Program Files\App\app.exe	OfficeSync → C:\Users\<user>\AppData\Roaming\office_sync.exe (creada por PS→Word)
Servicio Windows	SecurityAgentUpdater → C:\Program Files\SecurityAgent\updater.exe	WindowsUpdateCheck → C:\Windows\Temp\svc.exe (creado remotamente)
Carpeta de Inicio	Herramienta colaboración → app.exe en Program Files	update.lnk → C:\Users\Public\update.exe
Regla de correo / MFA	Cambio aprobado con ticket de IT	Login desde IP extranjera → regla de reenvío → nuevo método MFA

La persistencia no siempre es técnica. A veces es un usuario nuevo o una extensión:

Persistencia en cuentas y grupos

- Creación de nuevo usuario local o de dominio
- Usuario existente agregado a Administrators
- Cuenta de servicio creada con privilegios elevados
- Cuenta deshabilitada reactivada por el atacante
- Cambio de membresía en Domain Admins

⚠ Señal: net user /add o net localgroup Administrators /add fuera de horario y sin ticket

Persistencia en navegador

- Extensión de navegador instalada sin consentimiento
- Search redirect: cambio de motor de búsqueda predeterminado
- New Tab hijacking: página de inicio modificada
- Cookie theft vía extensión maliciosa
- Credenciales guardadas accedidas por proceso externo

⚠ Señal: PUA detected · Browser extension installed · Search redirect alert

⚠ **La creación de usuarios o cambios de grupo fuera de horario y sin ticket es una señal crítica de persistencia activa.**

4.5 | Tres mini escenarios de persistencia

Tres alertas con mecanismos distintos — tres análisis distintos:

RUN KEY sospechosa	SERVICIO REMOTO	REGLA CORREO + MFA
Alert: Registry Run key modified Host: FIN-LAP-022 User: finanzas.paz Key: HKCU\...\CurrentVersion\Run Value: OfficeSync Data: C:\Users\...\AppData\Roaming\office_sync.exe Modified by: powershell.exe / Parent: WINWORD.EXE	Alert: New service created Host: APP-SRV-03 User: admin.backup Service: WindowsUpdateCheck Binary: C:\Windows\Temp\svc.exe Time: 02:18 AM Ticket: None Related: SMB from USER-LAP-091	Alert: Mailbox forwarding rule created User: legal.romero Forward to: externalmail123@gmail.com Prev login: Foreign IP, Unknown device MFA: Success Endpoint alerts: None
⚠ Word → PS → modificó clave Run. Nombre engañoso, binario en AppData.	⚠ Servicio creado remotamente, binario en Temp, fuera de horario, sin ticket.	⚠ No hay malware en endpoint. Persistencia sobre cuenta comprometida.
→ Escalar. Posible persistencia tras doc malicioso.	*→ Escalar inmediato. Posible movimiento lateral.*	*→ Escalar para identidad y revisión de sesiones.*

El malware usa nombres que simulan software legítimo para pasar desapercibido:

Nombre sospechoso	Simula ser...	Señal real
`OneDriveUpdate.exe`	*Actualización legítima de OneDrive*	Binario en C:\Users\Public\ sin firma, creado por PowerShell
`WindowsUpdateCheck`	*Servicio de Windows Update*	Creado remotamente a las 2 AM sin ticket, binario en Temp
`OfficeSync`	*Sincronización de Office*	Run Key en AppData, modificada por proceso hijo de Word
`svchost32.exe`	*Proceso svchost.exe del sistema*	Nombre falso; svchost real vive solo en System32
`GoogleCrashHandler`	*Proceso de soporte de Chrome*	Binario en ruta de usuario, sin firma de Google
`AdobeUpdate.exe`	*Actualizador de Adobe*	Ejecutado desde Downloads, proceso padre: chrome.exe

Para documentar persistencia correctamente: indicar mecanismo, nombre del artefacto, ruta completa, proceso que lo creó y si hay contexto operativo (ticket, usuario técnico, horario).